INSPECCO × KRIPTARIUM

Safety 4.0 Bootcamp

Laboratuvar Föyleri · Seçilen Makine · Robotlu MIG/MAG Kaynak Hücresi

Yedi laboratuvarın tamamı, tek bir makine üzerinden ilerliyor: Hürmaksan Otomasyon Makina'nın robotlu kaynak hücresi (Pilz safety PLC + kameralı dikiş kontrolü).

LAB 1 · Safety Architecture	Çıktı: Safety Function Map
LAB 2 · IEC 62443 Mini Workshop	Çıktı: Zone / Conduit Diagram
LAB 3 · Threat & Risk + Risk Matrix	Çıktı: Risk Register
LAB 4 · Secure Remote Access	Çıktı: Secure Architecture
LAB 5 · SBOM / CVE / Patch	Çıktı: Vulnerability Decision
LAB 6 · CRA Incident Simulation	Çıktı: Incident Workflow
LAB 7 · AI Safety Challenge	Çıktı: AI Fail-Safe Decision

Hazırlayan: Büşra Erdem · Yazılım Mühendisliği, Fırat Üniversitesi Teknoloji Fakültesi
Ders: Yazılım Mühendisliğinde Güncel Konular
Makine: Hürmaksan Otomasyon — Robotlu MIG/MAG Kaynak Hücresi. Firma model detayı yayınlamadığı için hücre konfigürasyonu, firmanın web sitesindeki bilgilere (hurmaksan.com) dayanan örnek bir kurgudur.

Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir.

Safety Architecture

Çıktı: Safety Function Map

Ad Soyad Büşra Erdem **Grup** **Tarih**

> **Kavram:** Emniyet fonksiyonu, insanı koruyan fonksiyondur ve **ayrı bir safety yolunda** yaşar (E-stop → Safety PLC → STO). Gerekli güvenilirliği (PLr/SIL) riskle orantılıdır — ve bu güvenilirlik **dijital bir konfigürasyona** bağlıdır.

NORMAL KONTROL YOLU · üretim

Parça sensörleri → S7-1500 PLC → Robot · güç kaynağı · tabla → Uzak servis

dijital kesişim: ortak switch + uzak servisin safety konfigürasyonuna erişimi

SAFETY YOLU · koruma · AYRI

Kapı kilidi · ışık perdesi · E-stop → Pilz Safety PLC → Robot STO · kontaktör → Safe State

Görev — sırayla cevaplayın

1 Bu makinede tehlike nedir? İnsan neyden zarar görür?

Robot kolunun çarpması/sıkıştırması (en büyüğü: operatör döner tablaya parça yüklerken robotun hareket etmesi); kaynak arkı (UV, göz/cilt yanığı); sıcak parça ve sıçrantı (yanık, yangın); kaynak dumanı.

2 Safety function (emniyet fonksiyonu) hangisidir?

Yükleme tarafındaki ışık perdesi kesilince veya çit kapısı açılınca robot hareketini ve kaynak arkını güvenli şekilde durdurmak. Ek olarak E-stop ile acil durdurma.

3 Safety-related control system nerede? Şemada işaretleyin.

Şemadaki kırmızı yolun tamamı: kapı kilidi, ışık perdesi, E-stop, Pilz safety PLC, robot STO girişi, güç kaynağı kontaktörü.

4 Normal PLC ile Safety PLC farkı nedir?

Normal PLC üretimi yönetir (sıralama, reçete, tabla); hatası ürünü bozar. Safety PLC yalnızca insanı korur; çift kanallı, kendini test eden, sertifikalı donanımdır ve hata olursa makineyi her zaman durdurma yönüne çeker.

5 PLr / SIL neden var? Bu fonksiyon için neden önemli?

Koruma riskle orantılı olmalı. Ağır yaralanma (S2), sık maruziyet (F2), kaçınma zor (P2) → yaklaşık PL d / SIL 2 gerekir. Bu seviye safety PLC konfigürasyonuna bağlıdır; konfigürasyon değişirse PL de değişir.

6 Safe state (güvenli durum) nedir?

Robot STO ile durmuş ve torku kesilmiş, ark kapalı, döner tabla hareketsiz. Yeniden başlatma yalnızca kapı kapanıp operatör reset verince.

7 Safety function hangi dijital bağımlılıklara sahip?

Safety PLC konfigürasyonu ve parolası; robot kontrolöründeki güvenli hız/bölge ayarları; PROFIsafe haberleşmesi; ışık perdesi muting/blanking parametreleri; bunları değiştiren mühendislik dizüstü bilgisayarı.

8 Siber müdahale hangi noktadan bu fonksiyonu bozar?

Uzak servis bağlantısı veya servis dizüstü bilgisayarı üzerinden ışık perdesine muting verilmesi ya da robotun güvenli bölge sınırlarının genişletilmesi → operatör yüklerken robot hareket eder.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad Büşra Erdem **Grup** **Tarih**

> **Kavram: Zone** = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı.

Görev A — varlıkları bölgelere ayırın

Varlık listesi: S7-1500 PLC · HMI · Robot kontrolörü · Güç kaynağı · **Pilz Safety PLC** · Dikiş kamerası + IPC · MES · Mühendislik istasyonu · Uzak servis erişimi · Ofis ağı

1 Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Zone 1 · Safety
Pilz safety PLC, ışık perdesi, kapı kilidi, E-stop zinciri

Zone 2 · Kontrol (hücre)
S7-1500 PLC, robot kontrolörü, güç kaynağı, tabla sürücüsü, HMI

Zone 3 · Görüntü / YZ
Dikiş kamerası + IPC

Zone 4 · DMZ
Jump server, yama/güncelleme sunucusu

Zone 5 · Kurumsal IT
Ofis ağı, ERP/MES, e-posta, mühendislik istasyonu (OT'ye yalnızca DMZ üzerinden)

2 Safety PLC'yi hangi bölgeye koydunuz — neden?

Kendi ayrı bölgesine (Zone 1), en yüksek güvenlik seviyesinde. İnsanı koruyan tek fonksiyon orada; kontrol bölgesi ele geçirilse bile safety mantığı değiştirilememeli. Kontrol bölgesine yalnızca durum bilgisi verir.

3 Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

Z2↔Z1: yalnızca PROFIsafe + durum okuma; konfigürasyon yazma yalnızca yerinde, fiziksel anahtarla. Z3→Z2: IPC sadece OK/RED gönderir, robot parametresi yazamaz. Z4↔Z2: uzak servis yalnızca jump server'dan; MFA, kişisel hesap, oturum kaydı. Z5↔Z4: firewall; yalnızca MES verisi ve onaylı güncellemeler. USB/servis dizüstü: yalnızca taranmış, kayıtlı cihaz.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	**Jump server** — tedarikçi DMZ'deki tek kontrollü noktadan girer.
Tünel?	Açık / VPN	**VPN** — trafik şifreli; robot/PLC portları internete açık kalmaz.
Kimlik?	Parola / MFA	**MFA** — parola çalınsa bile giriş yapılamaz.
Hesap?	Paylaşılan / Kişisel	**Kişisel** — kim ne yaptı izlenir, ayrılanın hesabı kapatılır.
Kayıt?	Yok / Tam oturum kaydı	**Tam oturum kaydı** — olayda kanıt; safety ayarına dokunuldu mu görülür.
Zamanlama?	Sürekli açık / Varsayılan kapalı	**Varsayılan kapalı** — vardiya sorumlusu onayıyla, süreli (ör. 2 saat) açılır.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad Büşra Erdem **Grup** **Tarih**

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır.

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim → kapı → zincir → fiziksel sonuç)	L	S	E	Skor	Öncelik
1. Fırsatçı dış saldırgan → internete açık uzak servis bağlantısı (paylaşılan hesap) → robot kontrolörüne girer → güvenli bölge sınırlarını genişletir / ışık perdesine muting verir → operatör parça yüklerken robot hareket eder: ezilme, çarpma yaralanması	3	3	3	**27**	Kritik
2. Tedarik zinciri → servis teknisyeninin enfekte dizüstü bilgisayarı → PLC'ye zararlı yazılım → duman emiş fanı durur, HMI "çalışıyor" gösterir → kapalı alanda kaynak dumanı birikir: zehirlenme, yangın riski	2	3	2	**12**	Yüksek S=3
3. Meraklı içeriden → HMI'daki ortak operatör hesabı → kaynak reçetesinde akım/voltajı yükseltir → aşırı sıçrantı ve sıcak parça: yanık, yangın; zayıf dikişli parça müşteride kırılır	2	2	1	**4**	Orta

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1 **En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?**

Senaryo 1 — internete açık, kolay istismar edilen bir kapıdan doğrudan insanı koruyan safety fonksiyonuna ulaşıyor ve sonucu ağır yaralanma.

2 **S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?**

Evet, Senaryo 2 (skor 12, S=3). Risk register'da ayrı bir "S=3" kırmızı işaretiyle gösterilir, Kritik senaryoyla birlikte en üste alınır ve 90 günlük plana zorunlu girer.

Altın kural kontrolü: Üç senaryo da fiziksel bir sonuçla (yaralanma, zehirlenme, yangın) bitiyor; "veri çalındı" ile biten senaryo yok.

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad Büşra Erdem **Grup** **Tarih**

> **Kavram:** İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT

Tedarikçi → İnternet → 4G modem → Robot + PLC

- Ara nokta yok: cihazlara doğrudan erişim
- Ortak "service" hesabı
- Yalnızca parola
- 7/24 açık
- Oturum kaydı yok
- Aynı ağdan safety PLC konfigürasyonuna erişilebiliyor

HEDEF (beş ilkeyle)

Tedarikçi → VPN → Jump server (DMZ) → Kontrol bölgesi

- **1 · Ara nokta:** jump server tek giriş
- **2 · Hesap:** her teknisyene kişisel hesap
- **3 · Kimlik:** parola + MFA
- **4 · Zamanlama:** varsayılan kapalı, onayla süreli açılır
- **5 · Kayıt:** tam oturum kaydı
- Safety bölgesine ağdan yazma yok

Görev B — functional safety köprüsü

1 **Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?**

Mevcut durumda **evet**: robotun güvenli bölge ayarları ve safety PLC konfigürasyonu aynı ağdan değiştirilebiliyor. Hedef mimaride **hayır**: safety yolu kontrol sisteminden bağımsız; saldırgan üretimi durdurabilir ama kapı açıkken veya ışık perdesi kesilmişken robotu hareket ettiremez.

2 **Emniyet fonksiyonunun kontrol sisteminden bağımsız çalışması için GEREKSİNİMİ yazın (çözümü değil).**

"Işık perdesi / kapı kilidi / E-stop → robot STO emniyet fonksiyonu, normal kontrol sistemi (PLC, robot kontrolörü, IPC) ve uzak erişim yolu tamamen ele geçirilmiş olsa bile tasarlanan PL seviyesinde çalışmaya devam etmelidir. Emniyet parametreleri ağ üzerinden değiştirilememeli; her değişiklik yerinde, yetkili kişi tarafından yapılmalı ve kayıt altına alınmalıdır."

Tarafsızlık notu: Bu föy çözüm tasarlamaz; gereksinimi tanımlar. Tasarım kararı üretici firmanındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad Büşra Erdem **Grup** **Tarih**

Kavram: SBOM = yazılım malzeme listesi · CVE = açığın kayıt no'su · CVSS = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.
Makine: Hürmaksan Otomasyon – robotlu MIG/MAG kaynak hücresi (S7-1500 PLC, Pilz safety PLC, robot kontrolörü, dikiş kamerası + IPC, uzak servis bağlantısı).

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi) — hücredeki S7-1500 PLC
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. **Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)**

   SBOM'a bakılır. **Var:** Component X, hücrenin S7-1500 PLC firmware'inde bulunuyor. **Sürüm:** Kurulu sürüm 2.4, etkilenen aralıkta. **Ulaşılabilir:** PLC kontrol bölgesinde ve uzak servis/MES bağlantısı oraya ulaşabiliyor. Üç şart da sağlandığı için **etkileniyoruz**.

2. **Üretimi hemen durdurur musunuz? Neden / neden değil?**

   Hayır, hemen durdurmayız. Önce telafi edici önlem alınır: uzak servis bağlantısı kapatılır, PLC'ye giden conduit kısıtlanır. Emniyet fonksiyonu (ışık perdesi/kapı → Pilz safety PLC → robot STO) ayrı çalıştığı için insan korunur. Açık safety PLC'yi de etkiliyorsa üretim durdurulur.

3. **Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?**

   Önce test. Aynı PLC modelli test düzeneğinde ya da üretici (Siemens / Hürmaksan) onaylı ortamda denenir; kaynak çevrimi, döner tabla ve robot haberleşmesi kontrol edilir. Mevcut firmware yedeklenir, yama planlı duruşta sahaya uygulanır.

4. **Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?**

   Yamanın değiştirdiği bileşen listesine (release notes) bakılır. Safety PLC firmware'ine, PROFIsafe haberleşmesine veya robotun güvenli bölge fonksiyonuna dokunuyorsa safety validation tekrarlanır: ışık perdesi, kapı kilidi, E-stop testleri ve durma süresi ölçümü. Yalnızca normal PLC'yi etkiliyorsa fonksiyon testi yeterlidir; karar değişiklik kaydına yazılır.

5. **Yama mümkün değilse compensating control (telafi edici önlem) ne olur?**

   Uzak servis varsayılan kapalı; PLC'nin ilgili portu firewall'da kapatılır; PLC ayrı alt bölgeye alınır; ağ izleme (anomali tespiti) eklenir; USB portları kilitlenir. Yama tarihi ve kalan risk risk register'a yazılır.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad Büşra Erdem **Grup** **Tarih**

Senaryo: Saat 10:15. Servis hesabında yetkisiz erişim tespit edildi. PLC konfigürasyonu değişmiş olabilir. Kaynak hücresi hâlâ çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri iyi bir müdahale akışının doğal kilometre taşlarıdır.

Görev — zaman çizgisini doldurun

1 **10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?**

Ararım: OT/bakım sorumlusu, IT güvenlik, iş güvenliği uzmanı, Hürmaksan servis.
İlk üç eylem: (1) Hücreyi kontrollü durdur, operatörleri robot alanından çıkar, robotu güvenli konuma al. (2) Uzak servis bağlantısını fiziksel olarak kes (VPN/4G), servis hesabını kilitle. (3) Saati, HMI ekranlarını ve alarmları fotoğrafla; hiçbir şeyi resetleme.

2 **İlk 2 saat: Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?**

Emniyet: Işık perdesi, kapı kilidi ve E-stop fiziksel olarak test edilir; safety PLC konfigürasyon checksum'ı kayıtlı değerle karşılaştırılır.
Kanıt: PLC ve robot programının mevcut hâli değiştirilmeden yedeklenir; jump server oturum kayıtları, firewall ve HMI olay logları dışa alınır.
Hesap: Servis hesabı ve aynı parolayı kullanan tüm hesaplar kapatılır. Hücre, temiz yedek yüklenip safety testi yapılmadan çalıştırılmaz.

3 **24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?**

Tespit zamanı; etkilenen ürün (kaynak hücresi, PLC modeli ve firmware sürümü); aktif istismar şüphesi; alınan ilk önlemler; aynı hücreyi kullanan diğer müşterilerin risk altında olup olmadığı.

4 **72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?**

Kök neden: ör. paylaşılan servis parolası çalındı. **Etki:** hangi konfigürasyon değişti, safety etkilendi mi. **Önlem:** kişisel hesap + MFA, varsayılan kapalı uzak erişim.
Kim: OT teknik analiz · IT log analizi · Safety sorumlusu emniyet doğrulaması · Yönetim bildirim ve müşteri iletişimi (A = Yönetim).

5 **14 gün — son rapor: Hangi loglar/kayıtlar korunmuş olmalı?**

Jump server oturum kayıtları, VPN ve firewall logları, PLC/robot programının olay anı ve temiz yedek kopyaları, safety PLC checksum kayıtları, HMI alarm geçmişi, değişiklik yönetimi kayıtları, safety test tutanakları.

En sık hata: "Resetleyip devam edelim" — o düğme kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Ad Soyad Büşra Erdem **Grup** **Tarih**

> **Kavram — Prediction ≠ Safety:** Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin dışında tanımlanmalıdır. Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.

Dikiş kamerası → YZ modeli (IPC) → OK / RED → Kaynak parametresi → Robot

YZ yalnızca kalite kararı verir. Robot hareketi ve emniyet fonksiyonu (Pilz safety PLC) üzerinde yetkisi yoktur.

Görev — üç başarısızlıkta güvenli davranış

1 Model yanlış sınıflandırdı: Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?

Zayıf dikişli taşıyıcı parça müşteride kırılabilir. Kritik parçalarda her partiden örnekleme ile **ikinci kontrol** yapılır (insan gözü veya kesit/sızdırmazlık testi). YZ'nin önerdiği parametre düzeltmesi sabit güvenli sınırlarla (akım/voltaj min–max) kırpılır; sınır dışı öneri reddedilir.

2 Girdi manipüle edildi: Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?

Fark etme: Görüntü kalite kontrolü (bulanıklık, parlaklık, sıçrantıyla kirlenmiş lens), referans plakayla periyodik kalibrasyon, kamera–IPC arasında bütünlük kontrolü, art arda aynı kare gelmesi. **Şüpheli girdide:** Parça otomatik RED/karantina, parametre değişikliği dondurulur, son onaylı parametre setine dönülür, operatöre alarm verilir.

3 Confidence düştü: Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?

Eşik **%90** (pilot verilerle ayarlanır). %90 altı → parça "insana sor" kutusuna ayrılır, operatör onaylar. Art arda 3 düşük sonuç veya %70 altı → yeni çevrim başlatılmaz, son onaylı reçeteye dönülür (fallback), bakım çağrılır. Safety PLC ayrı çalıştığı için robot hareket güvenliği etkilenmez.

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	Kritik parçada örneklemeli insan kontrolü; YZ parametre önerileri güvenli sınırlarla kırpılır — **human override + fail-safe**
Girdi manipüle edildi	Görüntü kalite ve bütünlük izleme; şüphelide karantina, son onaylı parametreye dönüş, alarm — **monitoring + fallback**
Confidence düştü	%90 altı insana sor; art arda düşük veya %70 altı → dur, son onaylı reçete, bakım — **confidence threshold + fallback**

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.